

WIRELESS NETWORK AND IOT SECURITY

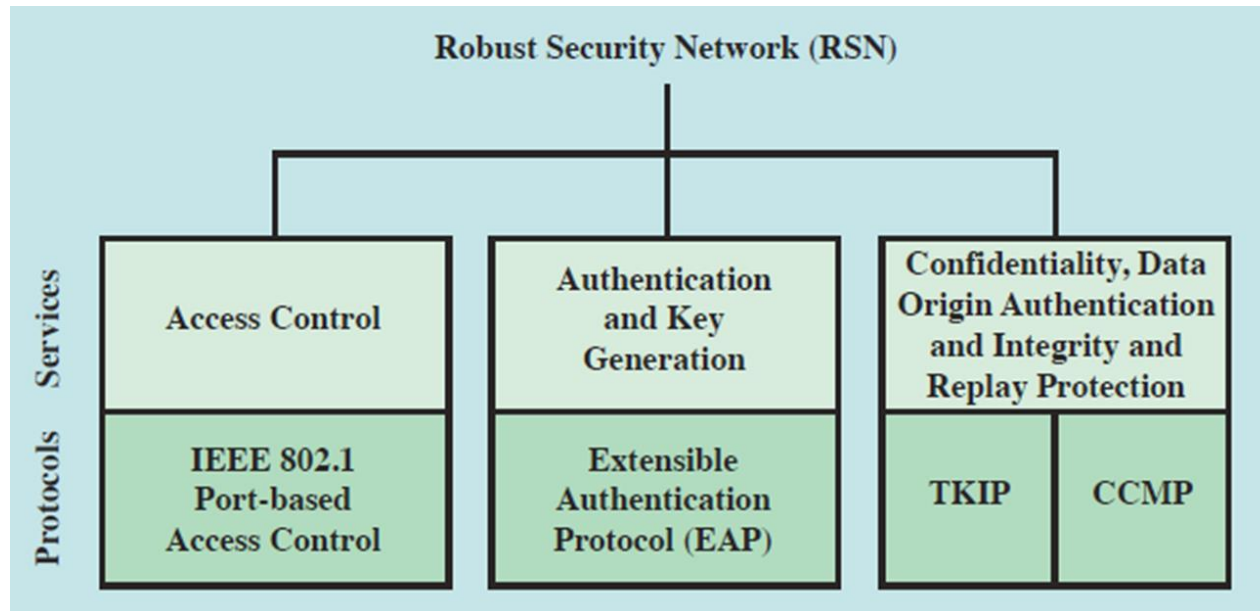
Lecture 11: Wi-Fi Protected Access 2 (WPA2)

Instructor: Kui Ren



Wi-Fi Protected Access 2 (WPA2)

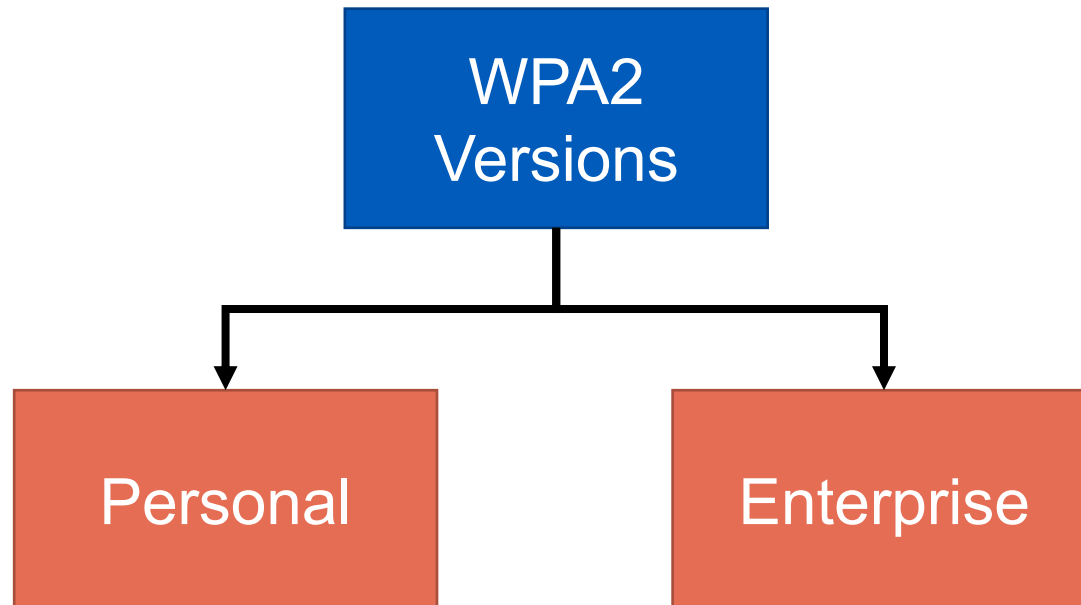
- Based on the IEEE 802.11i standard.
- The primary enhancement over WPA is the use of the **AES-based CCMP**



The final form of the 802.11i standard is RSN (Robust Security Network)

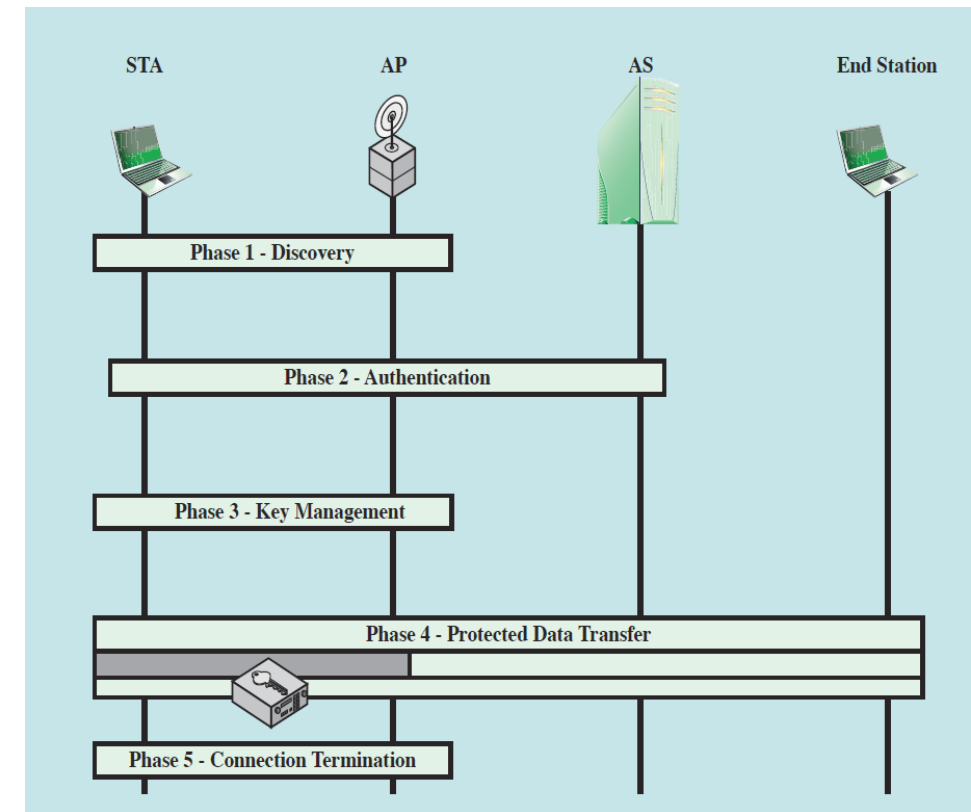
Wi-Fi Protected Access 2 (WPA2)

- The Personal mode uses a PSK (Pre-Shared Key) and doesn't require a separate authentication of users.
- The Enterprise mode requires the users to be separately authenticated by using the Extended EAP (Extensible Authentication Protocol).



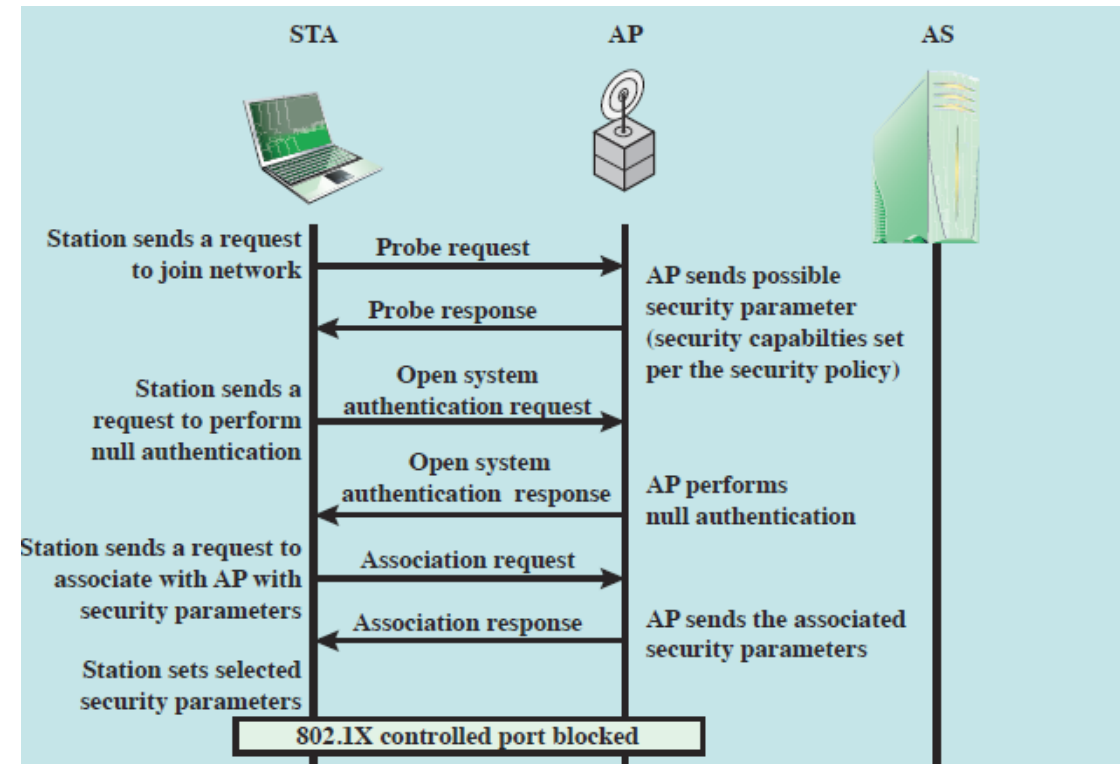
WPA2 Phases of Operation

- Phase 1: The AP and the client agree on the security policy
- Phase 2: Generate the **master key**
- Phase 3: Creating **temporary keys**
- Phase 4: All keys generated in phase 3 will be used by the CCMP protocol to provide data **confidentiality** and **integrity**



Phase 1: Discovery

- Capability Discovery
- Open System Authentication
- Association



Capability Discovery

- An AP uses messages called Beacons and Probe Responses to advertise its security capabilities
 - Advertised in an RSN Information Element (RSN IE)
- The STA uses these to identify an AP for a WLAN with which it wishes to communicate
- The STA associates with the AP, which it uses to select the cipher suite and authentication mechanism in Association Request

Open System Authentication

- The purpose of this frame sequence, is simply to maintain backward compatibility with the IEEE 802.11 state machine
 - It provides no security
- In essence, the two devices (STA and AP) simply exchange identifiers

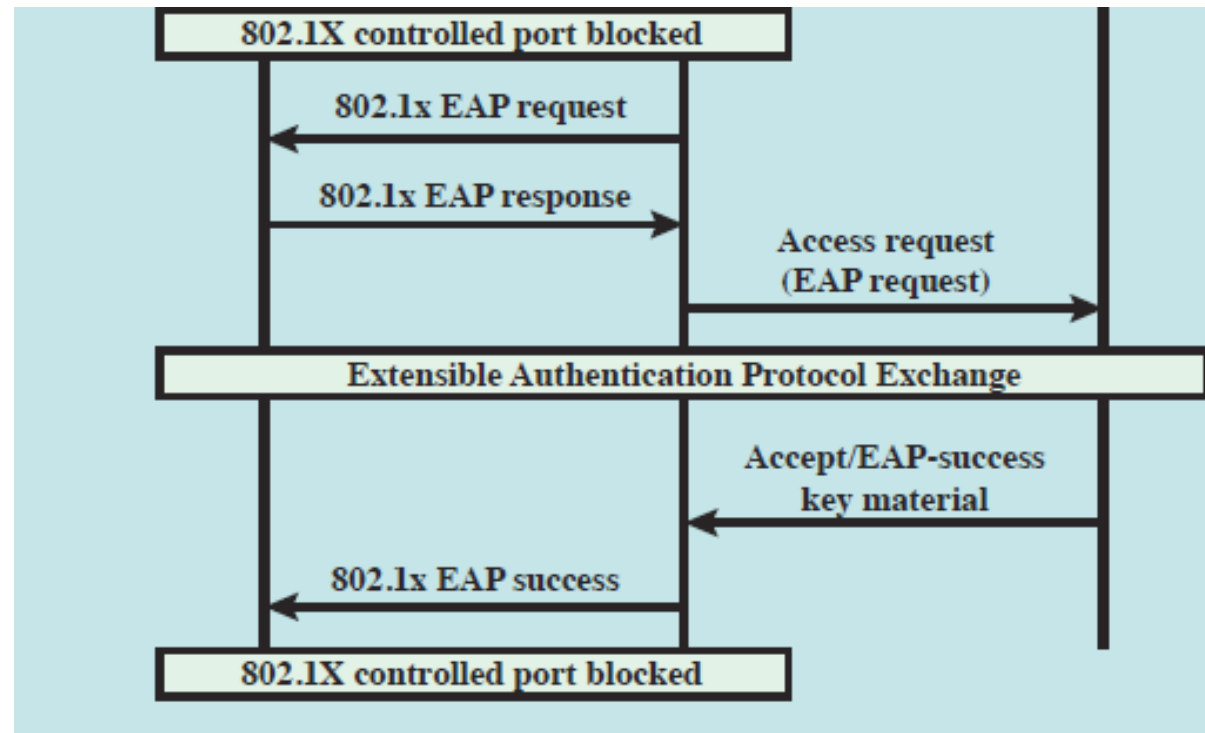


Association

- The purpose of this stage is to agree on a set of security capabilities to be used
- The STA then sends an Association Request frame to the AP.
 - Specify one set of matching capabilities (one authentication and key management suite, one pairwise cipher suite, and one group-key cipher suite) from among those advertised by the AP

Phase 2: Authentication

- This phase is based on EAP and the authentication method which has been agreed on in phase 1



Authentication Steps

1. Connect to AS

- The STA sends a request to its AP that it has an association with for connection to the AS;
- The AP acknowledges this request and sends an access request to the AS

2. EAP exchange

- Authenticate the STA and AS to each other

3. Secure key delivery

- Once authentication is established, the AS generates a **master session key** and sends it to the STA

EAP Exchange Process

1. Starts the 802.11X exchange with EAPOL-start message
2. Authenticator issues an EAP-request/identity frame
3. Supplicant replies with EAP-response/identity frame and passed to the radius server
4. Radius server determines the type of authentication required and sends an EAP-request for particular method type
5. The supplicant replies with an EAP-response/method frame
 - Steps 4 and 5 are repeated to complete the authentication
6. The radius server grants request with Radius-access-accept packet

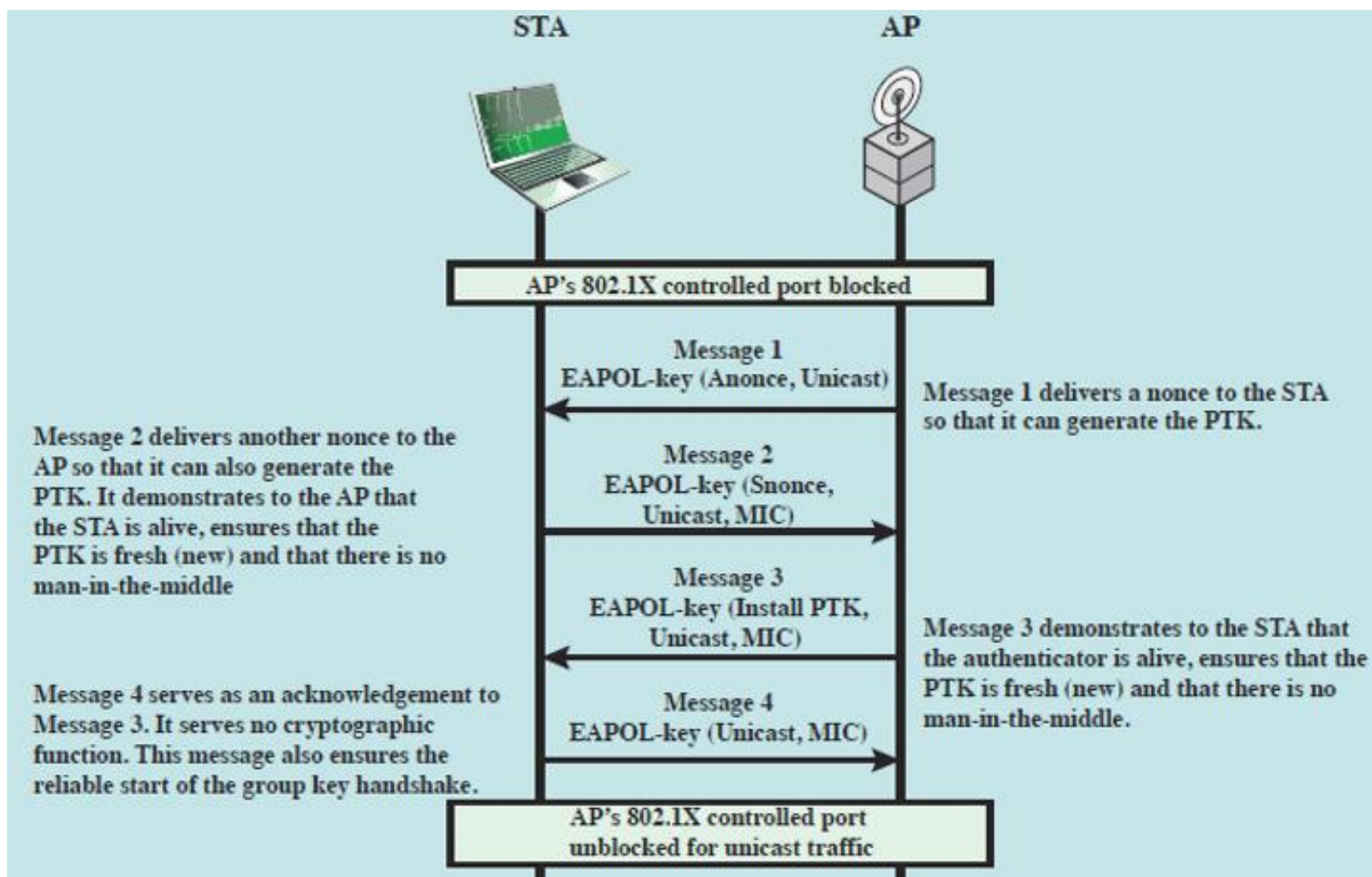
Phase 3 Key Management

- PMK – Pairwise Master Key
 - Sent from the AS to the Authenticator
 - Both the Supplicant and Authenticator now have the same PMK
- PMK is permanent for the entire session
- Must generate a Pairwise Transient Key for encryption of data.
 - Done using **4-way handshake**

Four-Way Handshake

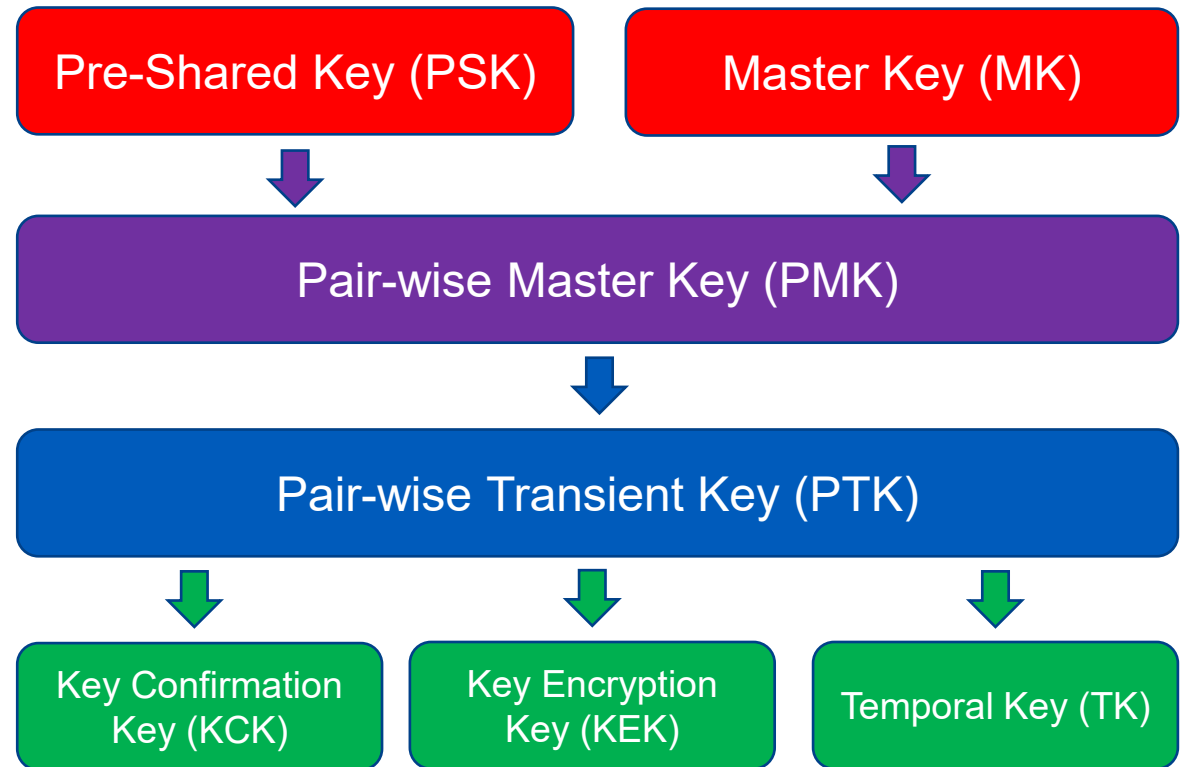
- Confirm that the client holds the PMK.
- Confirm that the PMK is correct and up-to-date.
- Create pairwise transient key (PTK) from the PMK.
- Install the pairwise encryption and integrity keys into IEEE 802.11.
- Transport the group temporal key (GTK) and GTK sequence number from Authenticator to Supplicant and install the GTK and GTK sequence number in the STA and, if not already installed, in the AP.
- Confirm the cipher suite selection.

Four-Way Handshake



Pairwise Key Hierarchies

- The PMK (Pairwise Master Key) derivation depends on what we have used on the authentication method
 - If we used **PSK (Pre-Shared Key)**, then the PMK will be equal to PSK.
 - If we used an **authentication server**, then the PMK will be derived from the 802.1X authentication MK.

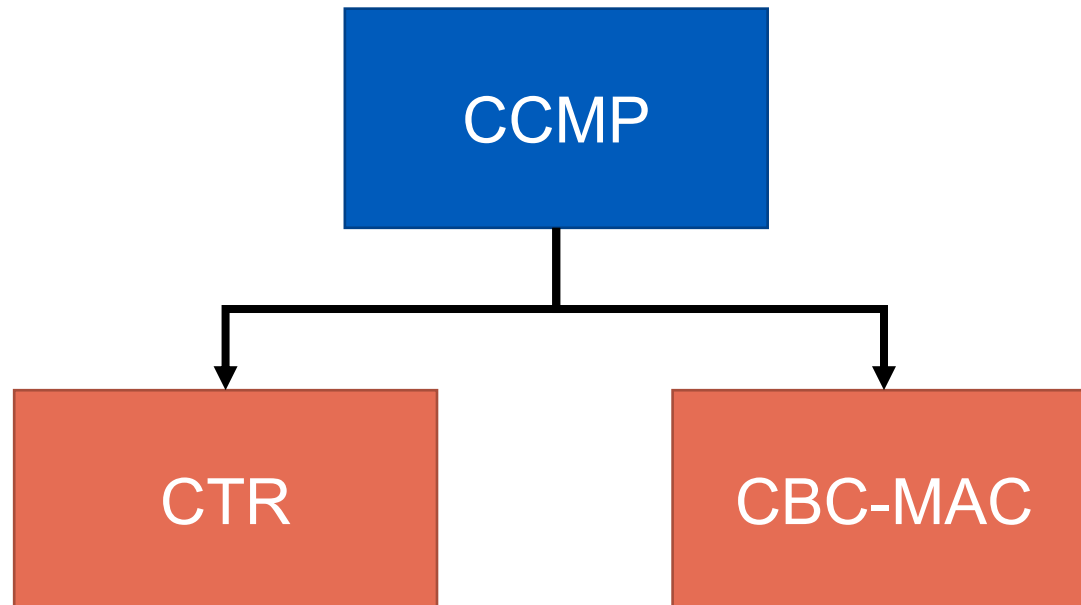


64 bytes Pairwise Transient Key

- 16 bytes of EAPOL-Key Confirmation Key (KCK)
 - Used to compute MIC on WPA EAPOL Key message
- 16 bytes of EAPOL-Key Encryption Key (KEK)
 - AP uses this key to encrypt additional data sent (in the 'Key Data' field) to the client (for example, the RSN IE or the GTK)
- 16 bytes of Temporal Key (TK)
 - Used to encrypt/decrypt Unicast data packets

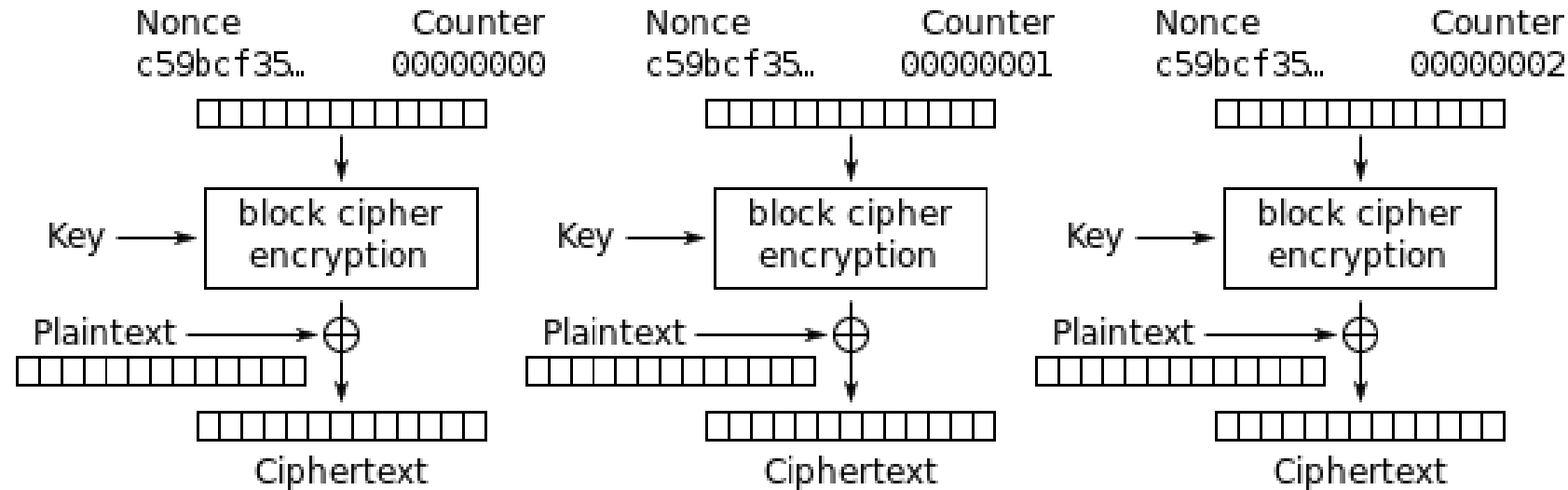
WPA2 Encryption

- The primary enhancement over WPA is the use of the AES (Advanced Encryption Standard) algorithm.
- 128 bit AES using the **Counter-Mode/CBC-MAC Protocol** (CCMP)



Counter Mode Encryption

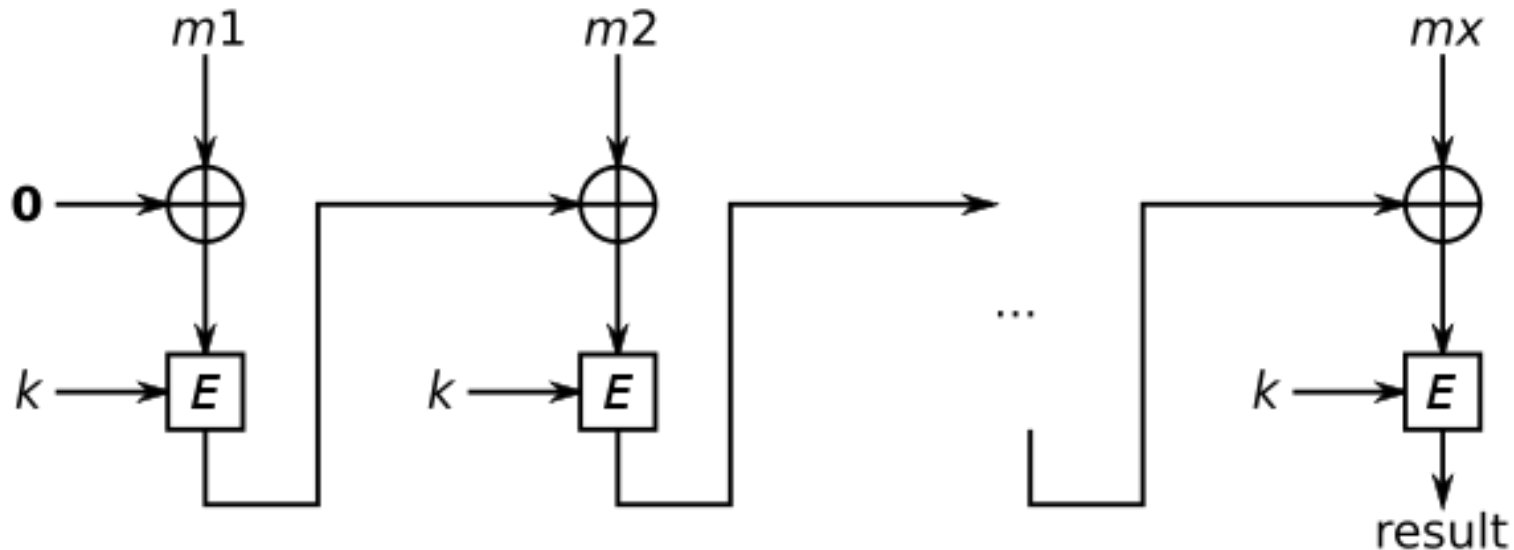
- The encryption service in WPA2 is based on the AES algorithm used in the CTR mode.
 - It generates the next keystream block by encrypting successive values of a "counter"



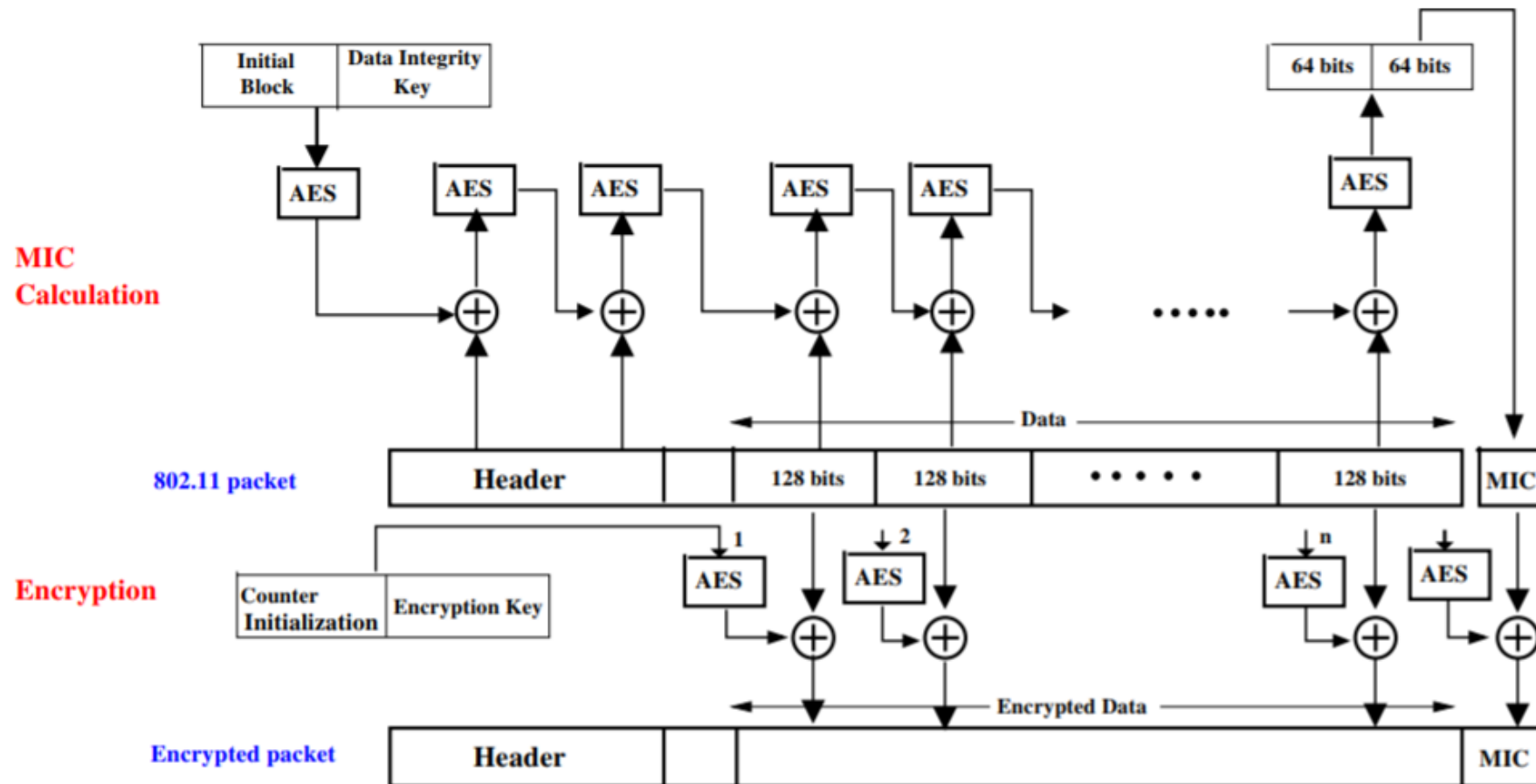
Counter (CTR) mode encryption

Cipher Block Chaining (CBC) - MAC

- In WPA2, the data integrity check is carried out by computing the CBC-MAC message authentication code
 - XOR each 128-bit block of the data with the AES encrypted value as obtained from the previous 128-bit block



Counter-Mode/CBC-MAC Protocol (CCMP)



AES – CCMP Features

- CCMP provides integrity protection over both the frame body and nearly the entire header in a MAC frame,
 - which prevents an adversary from exploiting the MAC headers
- CCMP uses a 48-bit Packet Number (PN)
 - to prevent replay attacks and construct a fresh nonce for each packet
- Analysis suggests that once CCMP is implemented,
 - an adversary will not be able to break the data confidentiality and integrity without the knowledge of the key



Encryption Method Comparison

	WEP	WPA	WPA2
Cipher	RC4	RC4	AES
Key Sizes	40 bits	128bits encryption 64 bits authentication	128 bits
Key Life	24 bit IV	48 bit IV	48 bit IV
Packet Key	Concatenated	Mixing Function	Not Needed
Data Integrity	CRC-32	Michael Algorithm	CCM
Header Integrity	None	Michael Algorithm	CCM
Defeat Replay Attacks	None	IV Sequence	IV Sequence
Key Management	None	EAP Based	EAP Based

WPA2 Pros

- The WPA2 has immunity against many types of hacker attacks, like:
 - Man-in-the-middle.
 - Authentication forging.
 - Replay.
 - Key collision.
 - Weak keys.
 - Packet forging.
 - Brute-force/dictionary attacks.



WPA2 Pros (cont.)

- WPA2 adds two enhancements to support fast roaming as follow:
 - Allow the client to reconnect to the access points which he has recently been connected to without needing to re-authenticate because of the PMK caching feature.
 - Allow the client to pre-authenticate himself with the access point which he is moving toward while he is still connected to the access point which he is moving away from.

WPA2 Cons

- Like all Wi-Fi security standard, the WPA2 can't stand in front of the physical layer attacks like:
 - RF jamming.
 - Data flooding.
 - Access points failure.



WPA2 Cons (cont.)

- The attacker can get and discover lots of network information by analyzing the unprotected control and management frames.
- It is vulnerable for the DoS attack.
- It is vulnerable to the MAC addresses spoofing and the mass de-authentication attacks.

The KRACK Attack

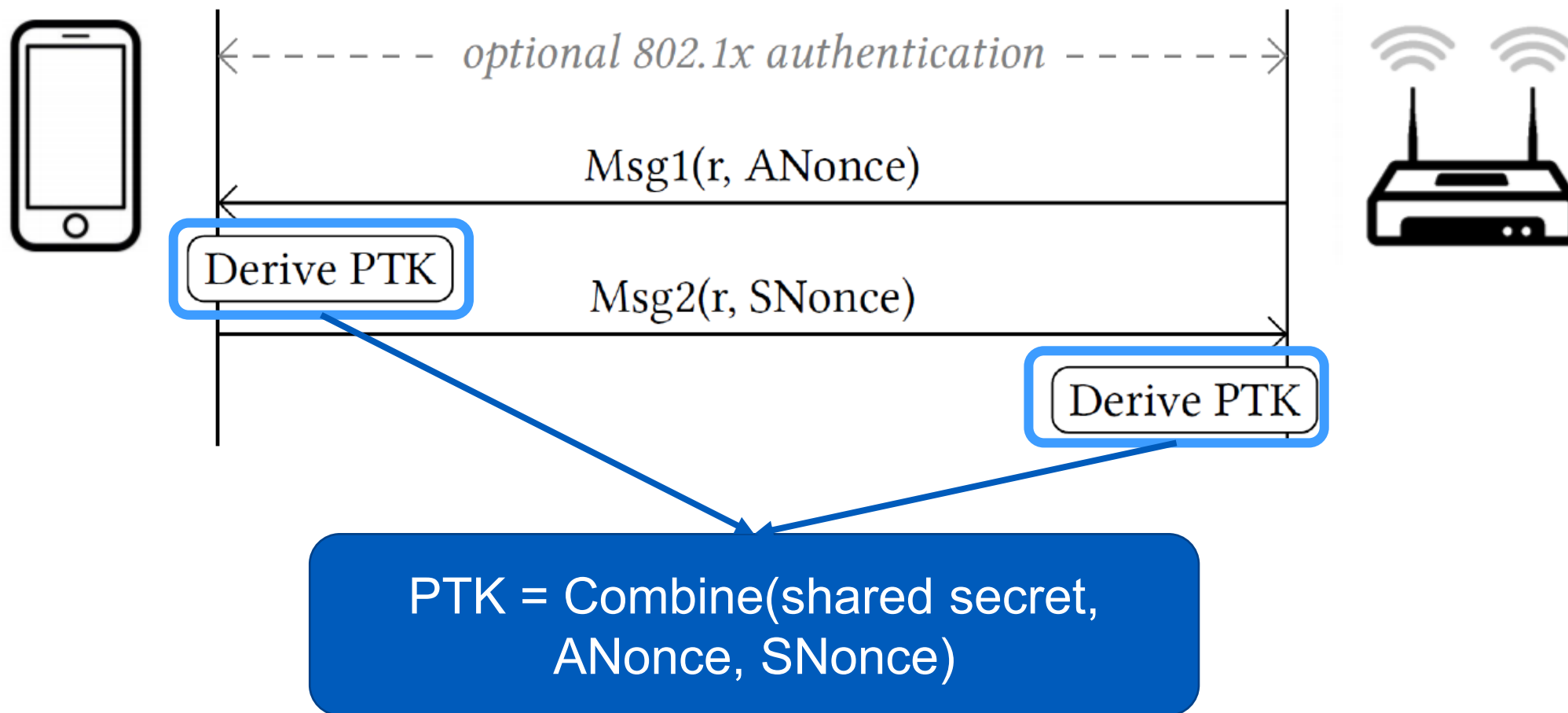
- KRACK is short for Key Reinstallation Attack
- The attack uses vulnerabilities in the 4-way handshake of the current WPA- 2 protocol.
- Threat level : Pretty bad – All Wi-Fi routers everywhere are vulnerable



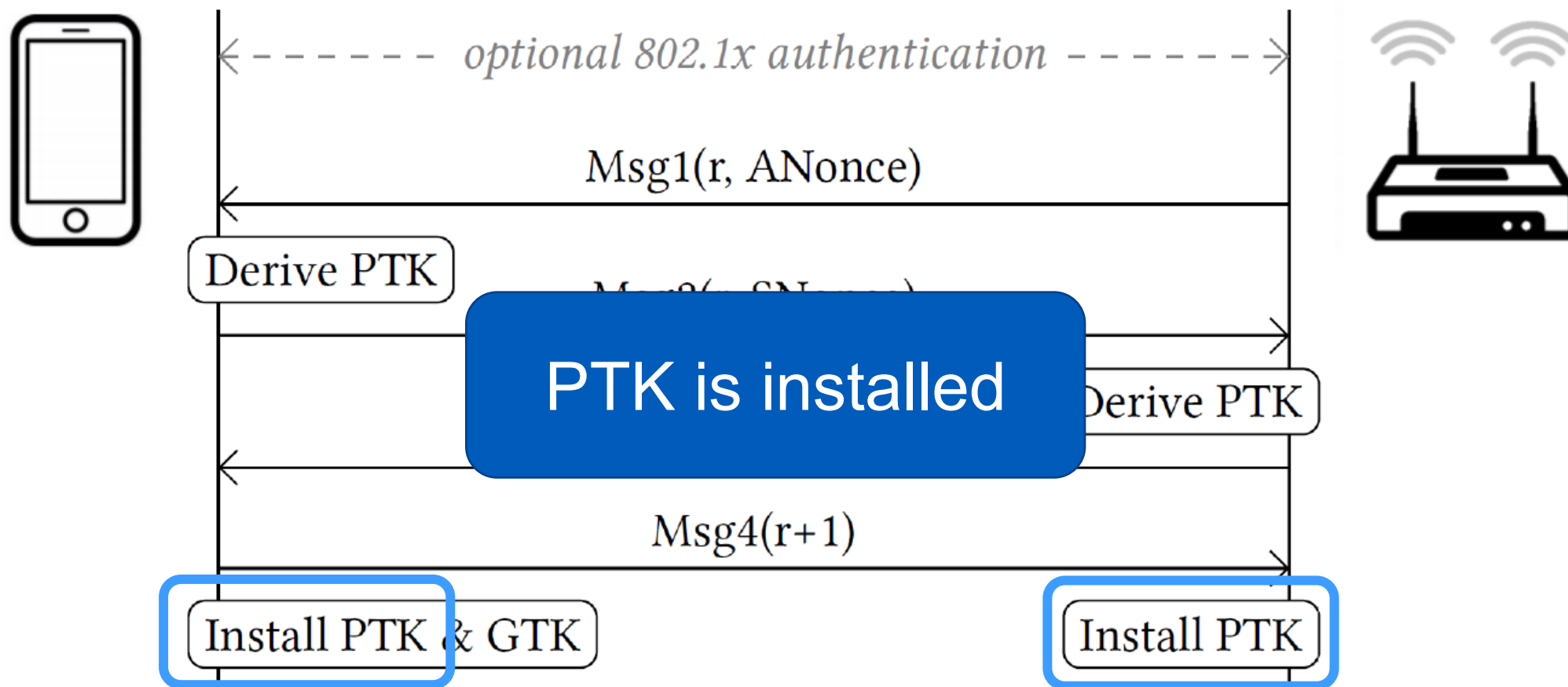
The 4-way handshake

- Used to connect to any protected Wi-Fi network
- Two main purposes:
 - Mutual authentication
 - Negotiate fresh PTK: pairwise temporal key
- Appeared to be secure:
 - No attacks in over a decade (apart from password guessing)
 - Proven that negotiated key (PTK) is secret
 - And encryption protocol proven secure

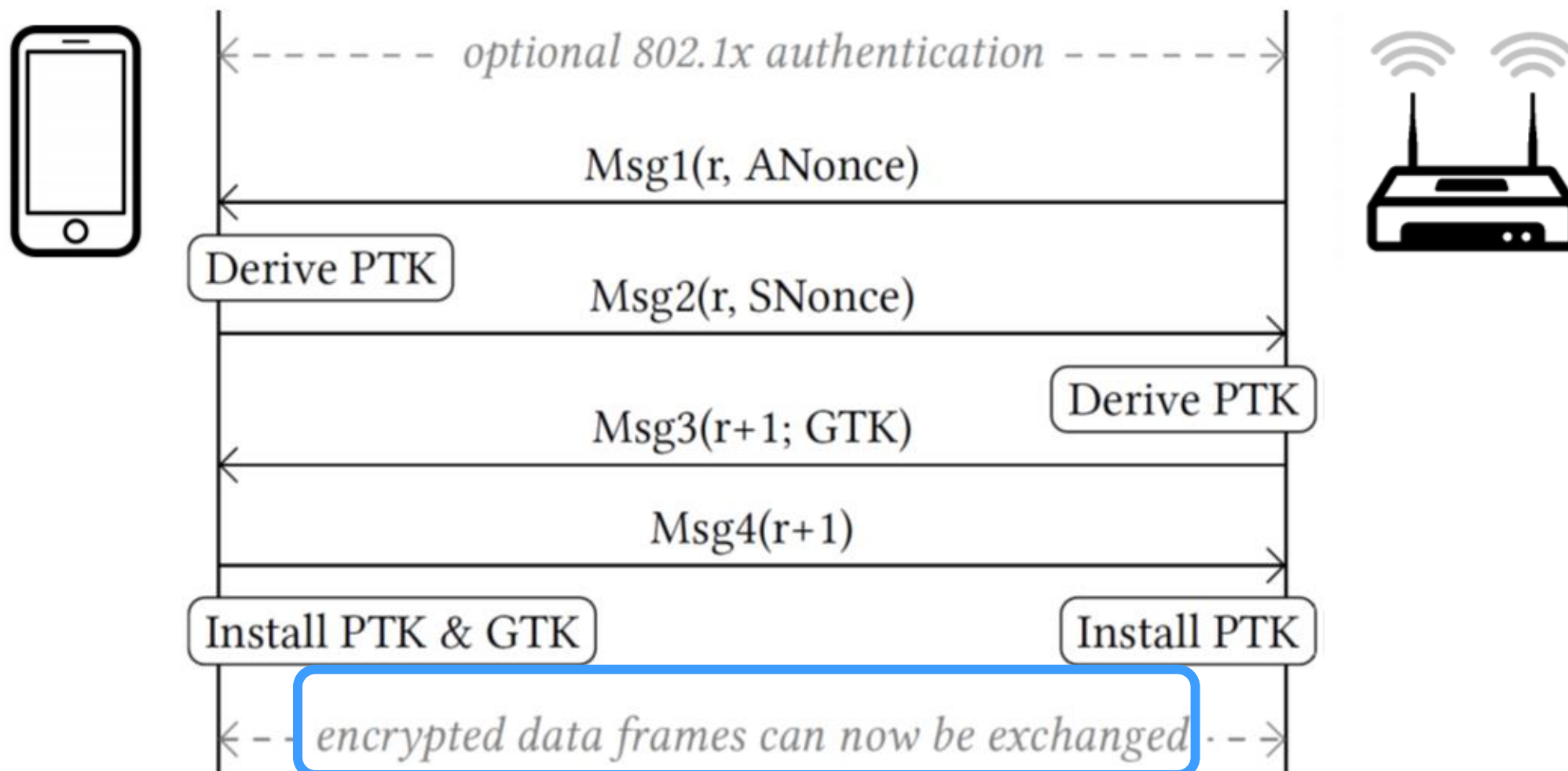
4-way handshake (simplified)



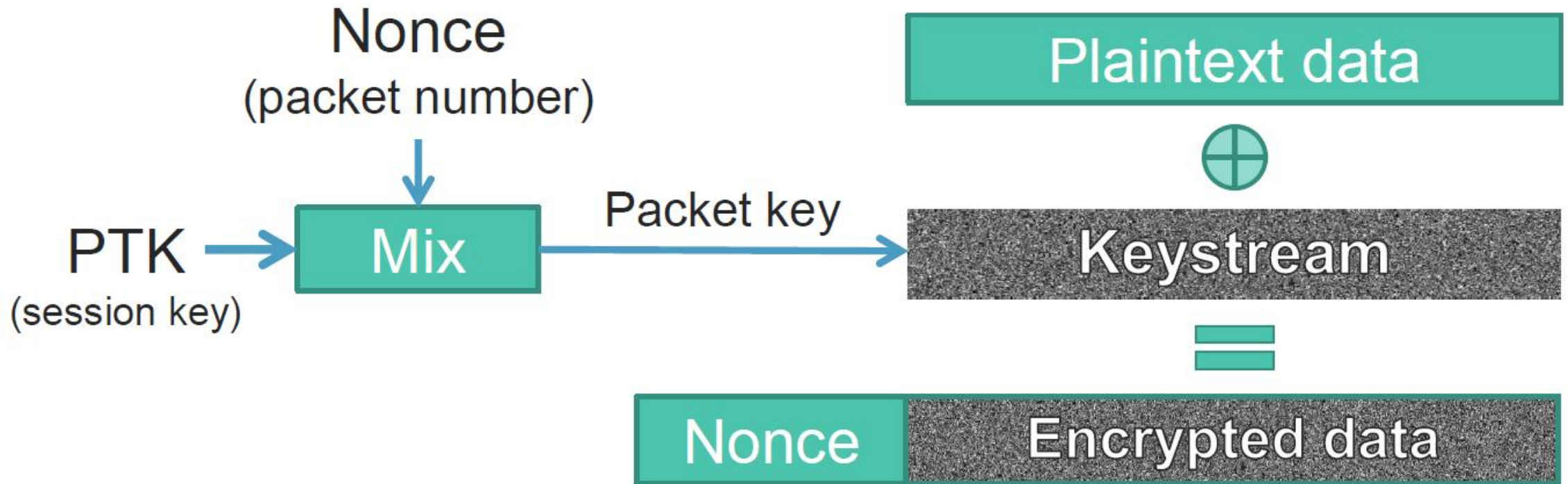
4-way handshake (simplified)



The Key Reinstallation Attack on WPA2

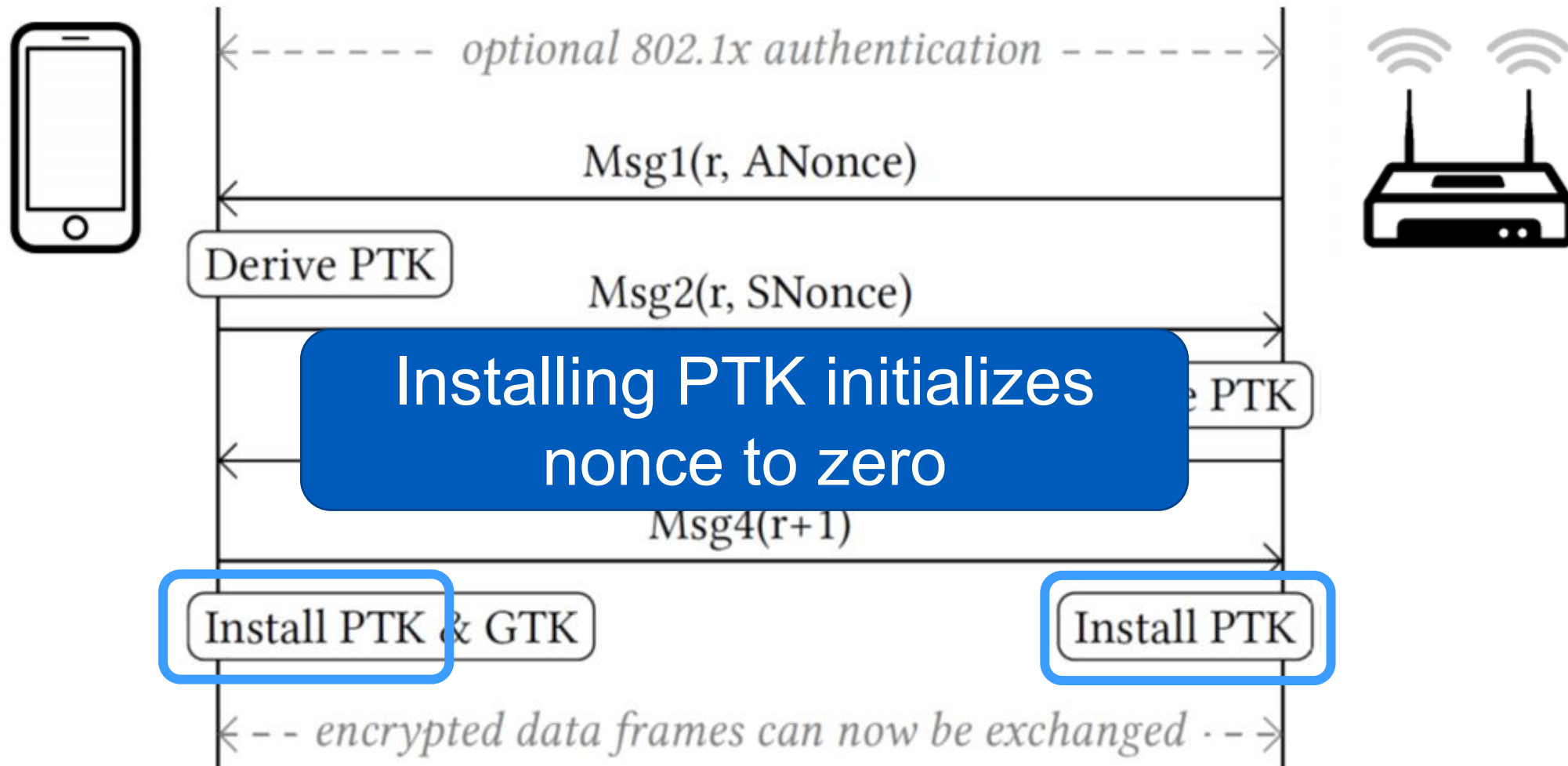


Frame encryption (simplified)

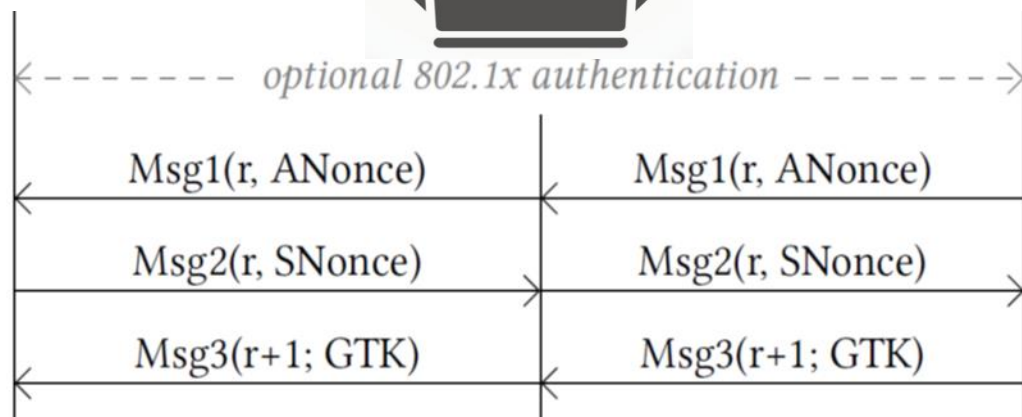


Nonce reuse implies keystream reuse (in all WPA2 ciphers)

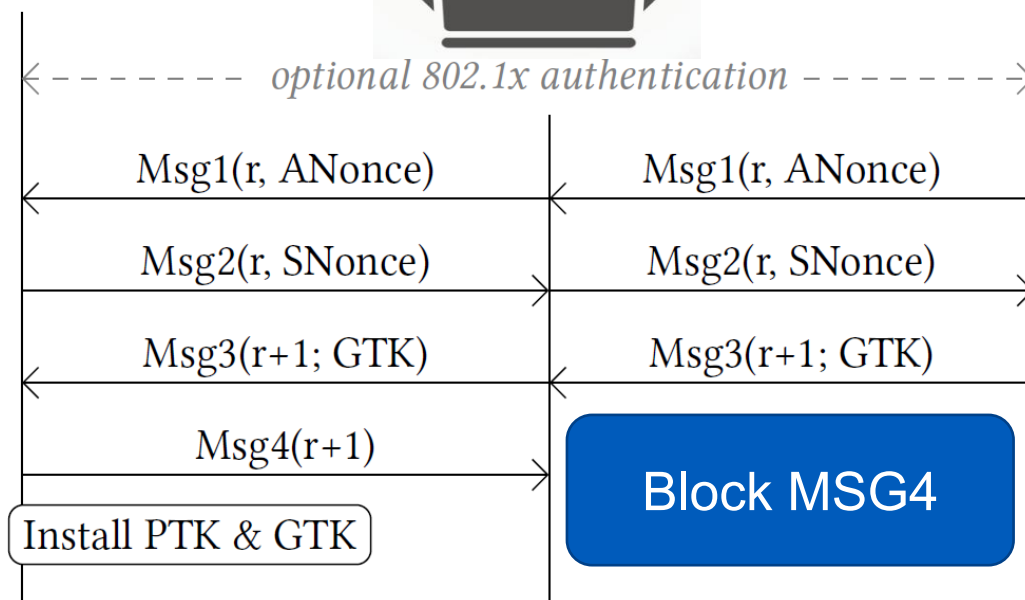
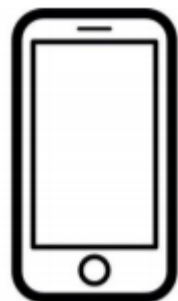
4-way handshake (simplified)



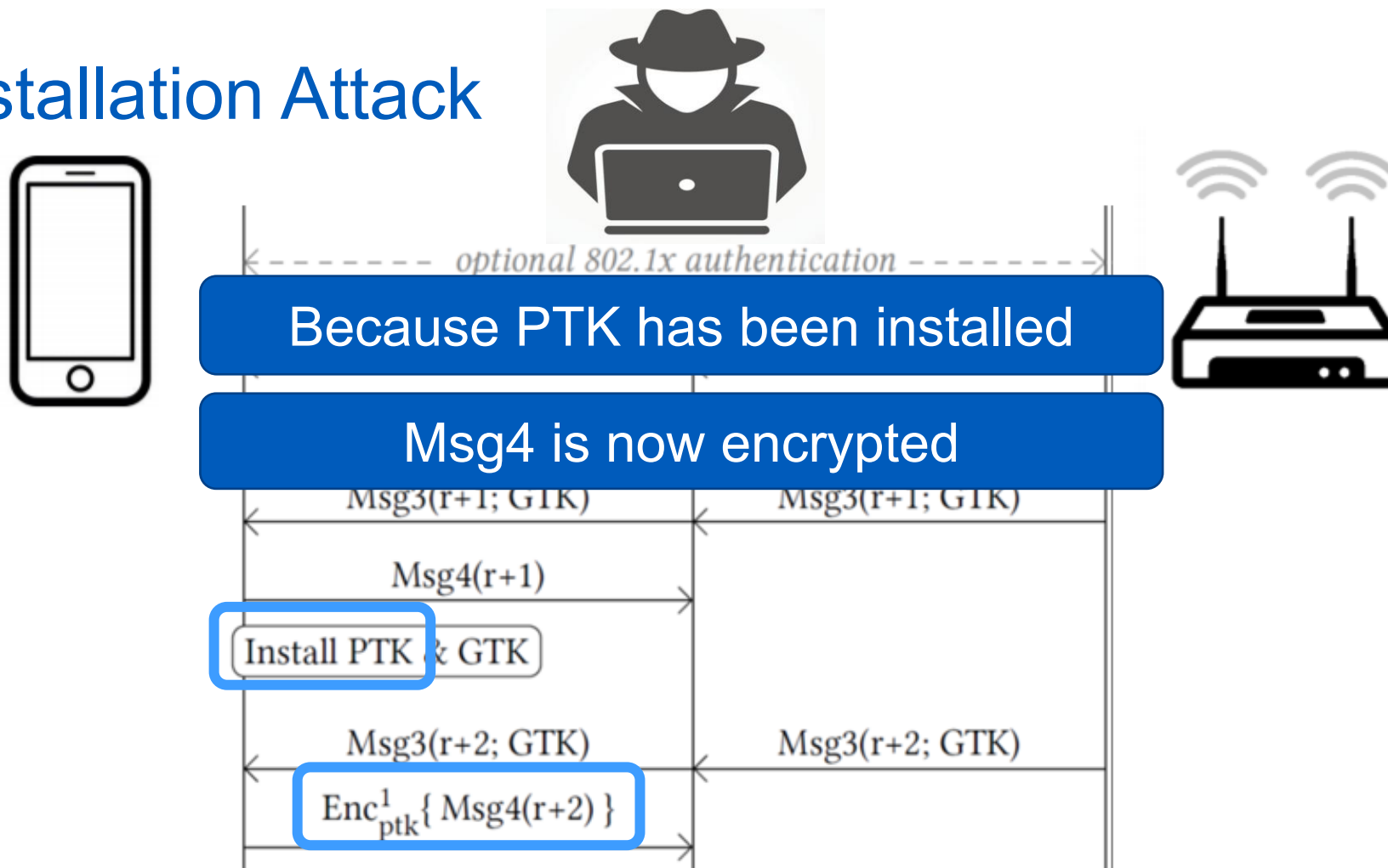
Reinstallation Attack



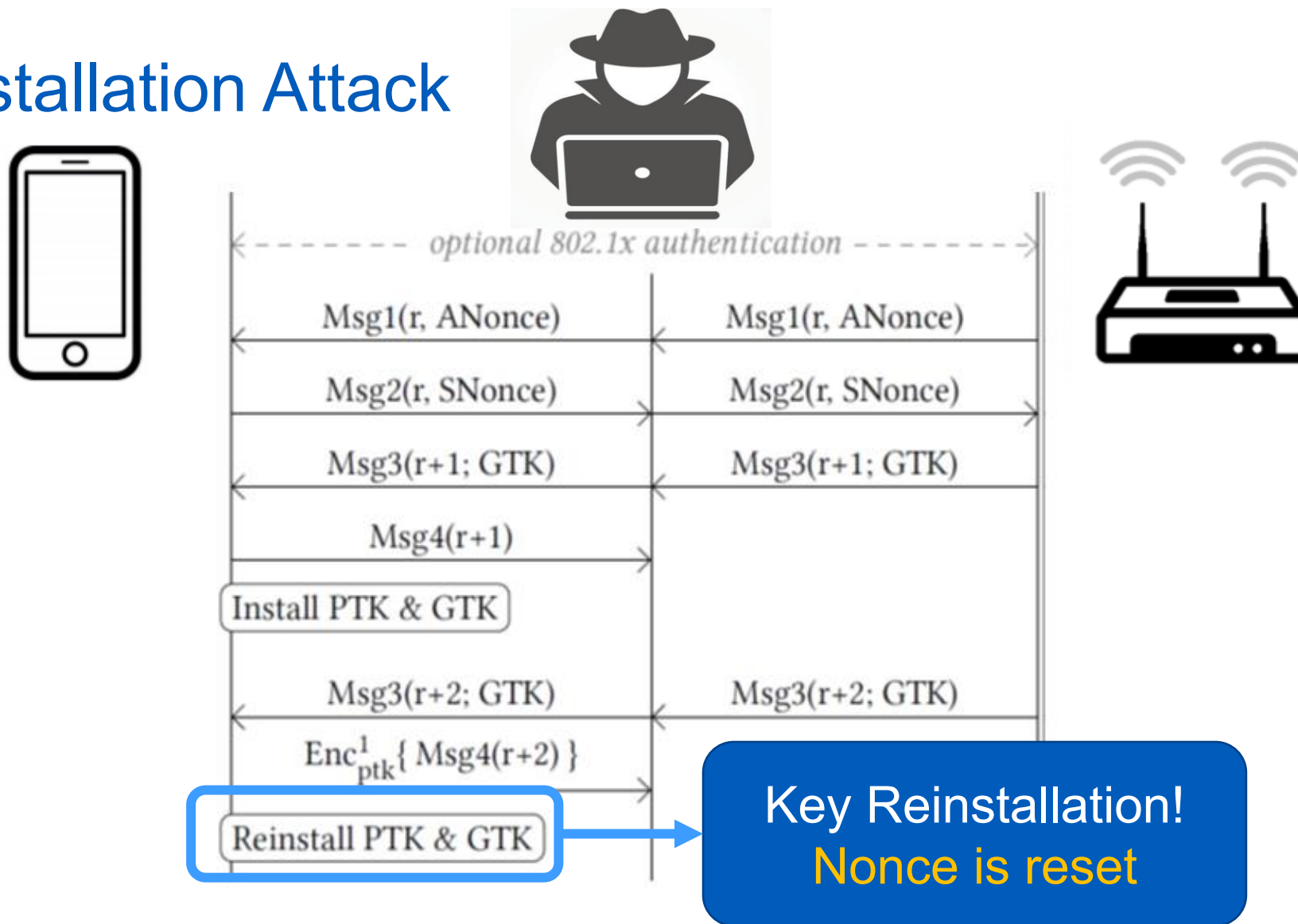
Reinstallation Attack



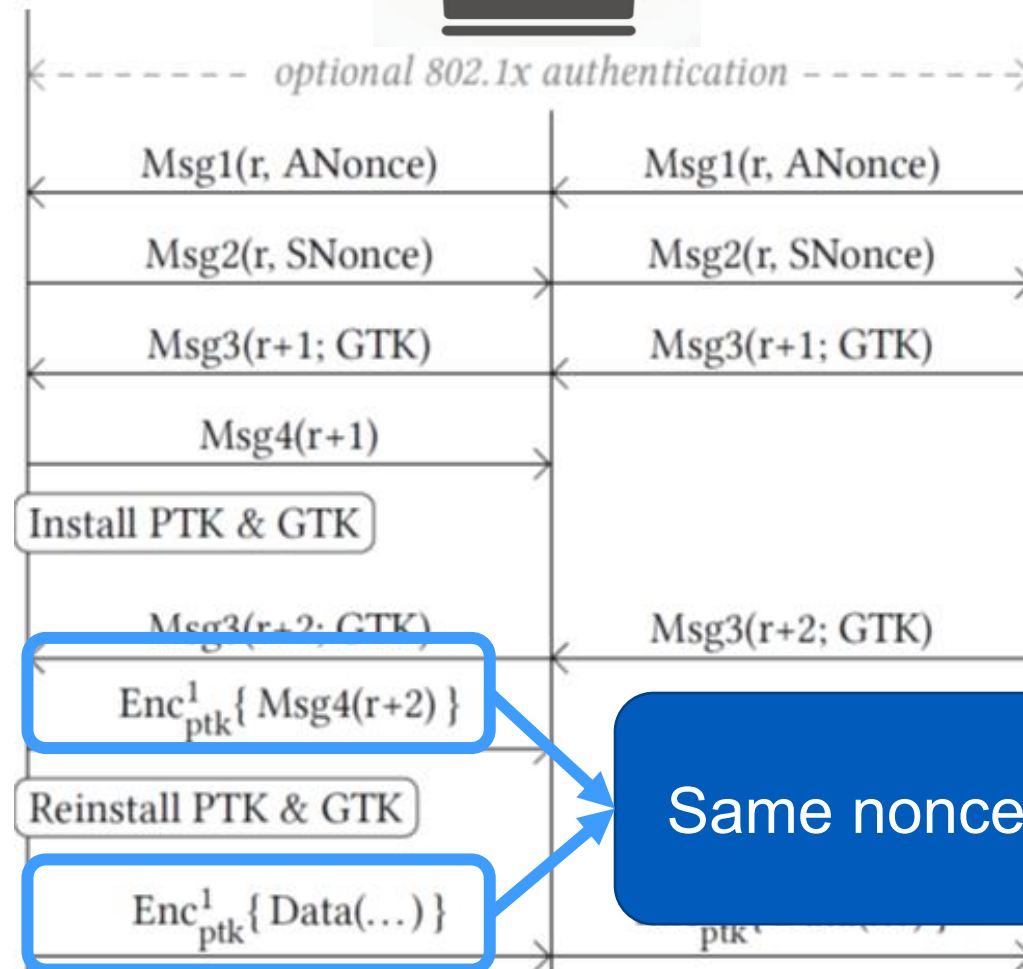
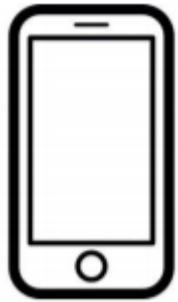
Reinstallation Attack



Reinstallation Attack

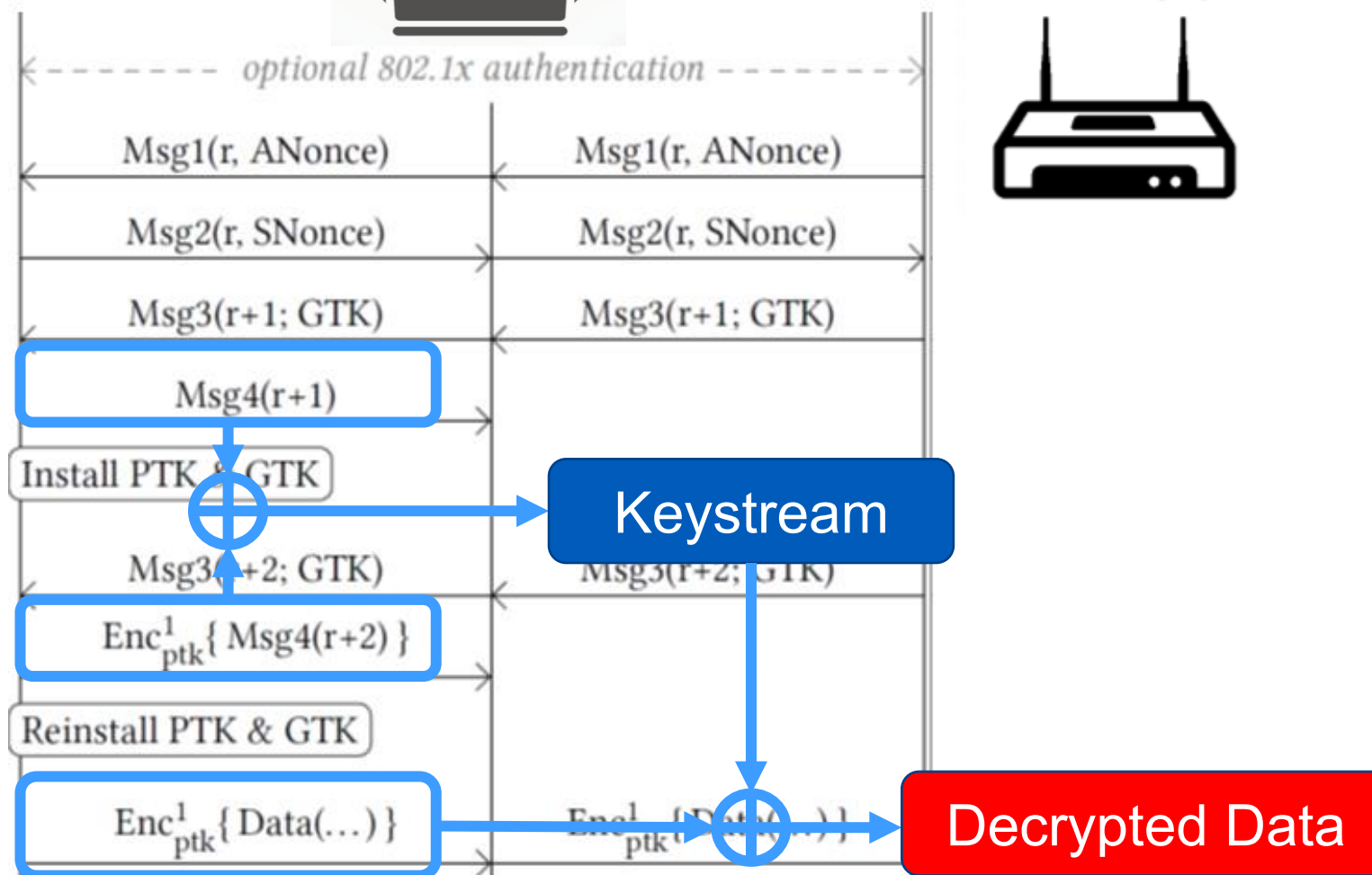


Reinstallation Attack



Same nonce is used

Reinstallation Attack



Key Takeaway

- Limitations of formal proofs:
 - WPA 4-way handshake has proven to be secure
 - Encryption ciphers have been mathematically proven to be secure
 - Combination is not proven secure
- Enterprise PMK was just as vulnerable as Personal pre-shared keys.
 - Creates a false sense of security.
- Abstract model $\neq$ real code
 - Must assure code matches specification